INF6103 : Cybersécurité des Infrastructures Critiques

TP 2 : Scénario d'intrusion contre les systèmes de contrôle industriels

---

Rapport de test d'intrusion

Équipe XX

Prénom Nom Matricule
Prénom Nom Matricule

Polytechnique Montréal

Automne 2026 — Remis le 3 novembre 2026

Table des matières

Sommaire exécutif **2**

1 Reconnaissance **2**
1.1 Cartographie des machines et services 2
1.2 Architecture réseau et modèle de Purdue 3
1.3 Accès à la page d'authentification 5
1.4 Tentative d'authentification 7

Sommaire exécutif

[À FAIRE : Résumé du mandat, des vulnérabilités critiques et de l'impact.]

Périmètre et conditions

— Point d'entrée : carte RasPi (`ssh root@ip_vm -p 2222`).
— Caméra de surveillance de la cuve : `http://ip_vm:80`.
— Interface de contrôle (tunnel) : `http://ip_vm:9090/`.
— Interface de programmation du PLC (tunnel) : `http://ip_vm:8080/`.

1 Reconnaissance

1.1 Cartographie des machines et services

Question 1.1 — *Identifiez les machines présentes sur le réseau et les services qu'elles offrent (tableau : adresse IP, nom d'hôte, ports ouverts, services).*

La découverte a été réalisée depuis la RasPi (`192.168.95.122`) avec `nmap -sV -p- -T4 192.168.95.0/24`. Onze hôtes actifs ont été identifiés (tableau 1).

TABLE 1 – Machines et services détectés sur le réseau `192.168.95.0/24`

Adresse IP	Nom d'hôte	Port ouvert		Service détecté (version)
`192.168.95.2`	`plc.scada`	502	tcp	Modbus/TCP
		8080	tcp	HTTP — Node.js (Express)
`192.168.95.5`	`ihm.scada`	8009	tcp	AJP13 — Apache JServ (protocole v1.3)
		9090	tcp	HTTP — Apache Tomcat/Coyote JSP 1.1
`192.168.95.10`–`.15`[a]	—	502	tcp	Modbus/TCP (`mbap?`)
		55555	tcp	Inconnu
`192.168.95.101`[a]	`simulation.scada`	80	tcp	HTTP — Apache httpd 2.4.18 (Ubuntu)
		55555	tcp	Inconnu
`192.168.95.254`	`inf6103-tp2`	22	tcp	SSH — OpenSSH 8.2p1 (Ubuntu)
		80	tcp	HTTP — Apache httpd 2.4.18 (Ubuntu)
		2222	tcp	SSH — OpenSSH 8.4p1 (Debian)
		8080	tcp	HTTP — Node.js (Express)
		9090	tcp	HTTP — Apache Tomcat/Coyote JSP 1.1
`192.168.95.122`	`2e66cc4cb86d`[b]	22	tcp	SSH — OpenSSH 8.4p1 (Debian)

[a] Les adresses `.10` à `.15` et `.101` partagent la même adresse MAC (`02:42:C0:A8:5F:65`) : il s'agit d'une seule machine possédant plusieurs adresses IP.
[b] Notre point d'entrée (RasPi).

1.2 Architecture réseau et modèle de Purdue

Question 1.2 — *Construisez une représentation de l'architecture du réseau industriel. Positionnez les actifs observés dans les niveaux appropriés du modèle de Purdue. Justifiez chaque positionnement à partir d'éléments observables.*

La figure 1 présente l'architecture du réseau industriel reconstituée à partir de la reconnaissance, avec chaque actif positionné dans le niveau correspondant du modèle de Purdue.

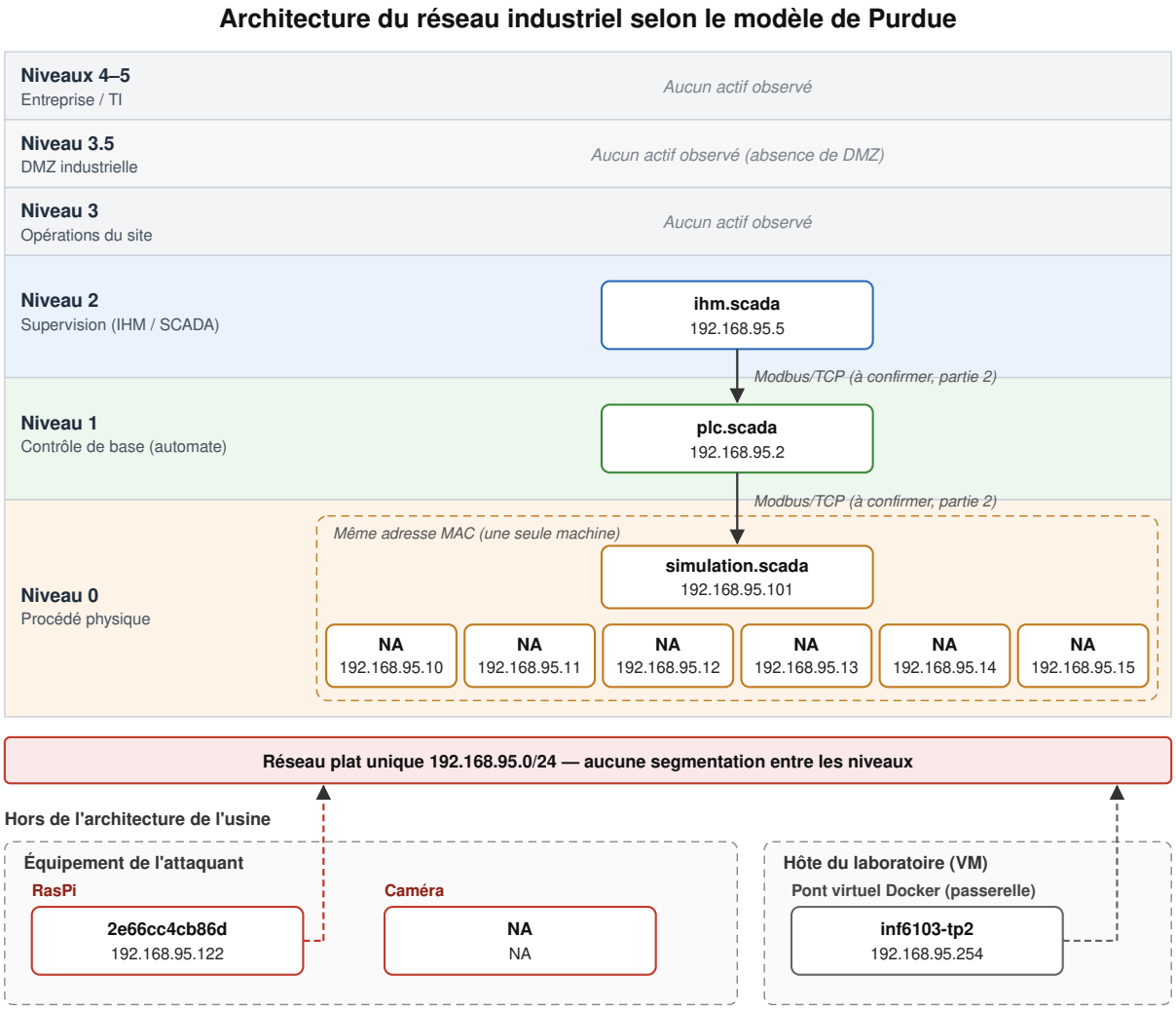


FIGURE 1 – Architecture du réseau industriel selon le modèle de Purdue

Le positionnment sur l'échelle de Purdue repose sur trois types d'informations observées :

1. Les protocoles exposés
2. Les noms d'hôte (scan `nmap -Sv`)
3. Les adresses MAC relevées lors du scan

Niveau 0 - Procédé physique : simulation.scada (192.168.95.101) et 192.168.95.10-15 Les six adresses exposent un serveur Modbus/TCP (port 502) et rien d'autre d'après notre scan. Elles

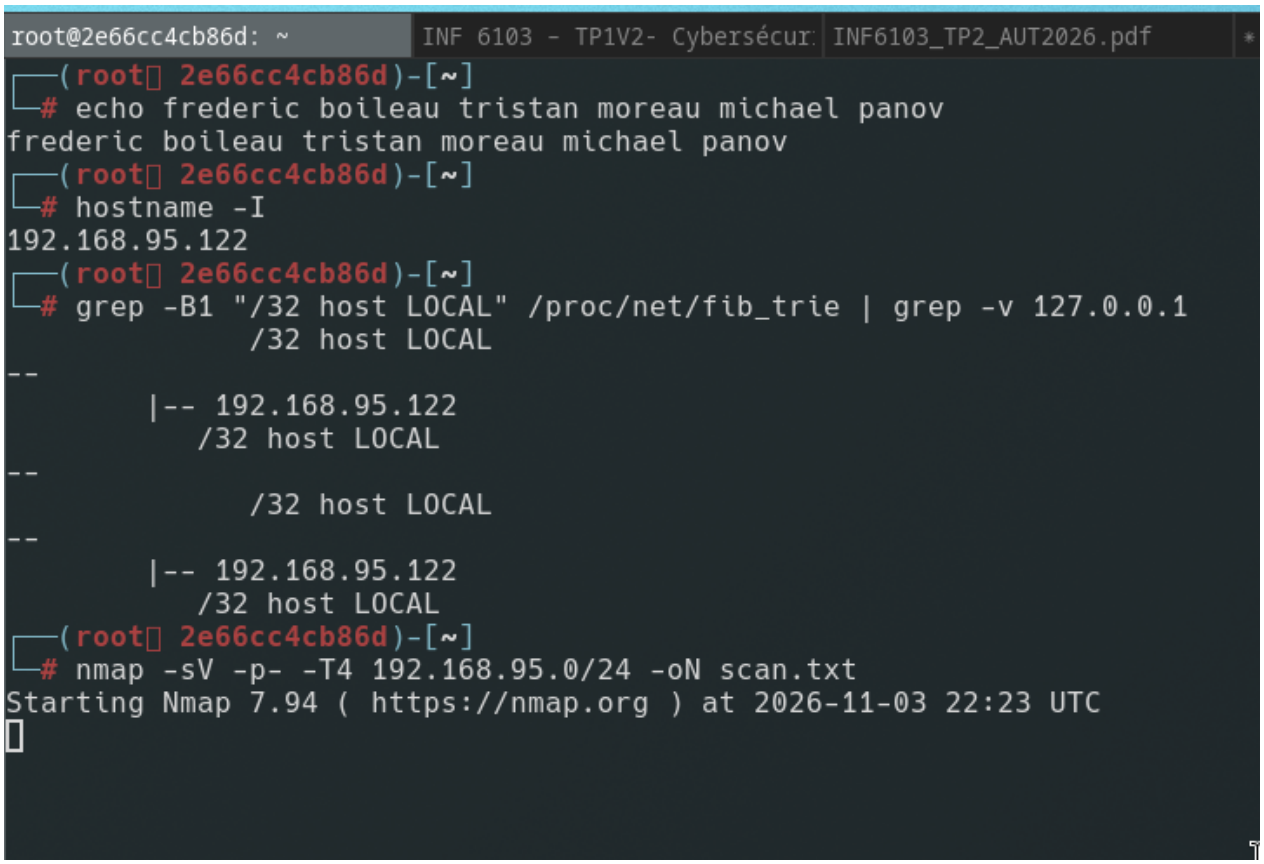
partagent toutes la même adresse MAC. Le nom d'hôte décrit explicitement le rôle de simulation de processus physique.

Niveau 1 - Contrôle de base : plc.scada (192.168.95.2) L'hôte expose un serveur Modbus/TCP, un protocole par lequel un PLC peut être lu et commandé par un superviseur. Il expose par contre aussi une application Node.js/Express au port 8080. De plus il public la même bannière que le port 8080 publié par la VM décrit dans l'énoncé comme une interface de contrôle de PLC. Finalement son nom d'hôte indique explicitement qu'il sagirait d'un PLC. Sous toute réserve on peut poser l'hypothèse qu'il sert de lien entre le niveau 2 de supervision et les processus physiques et leurs équipements (actuators, sensors) au niveau 0.

Niveau 2 - Supervision : ihm.scada (192.168.95.5) Cet hôte ne publie aucun port de type Modbus contrairement aux précédents. Il publie cependant le port 9090 qui selon nmap serait un serveur Apache Tomcat/Coyote. Il présente d'ailleurs la même bannière que le port 9090 publié par la VM décrit dans l'énoncé comme l'interface de contrôle du système industriel. Il y aussi le port 8009 (AJP13), probablemen une erreur de configuration puisque ce dernier est destiné à la connexion interne avec Tomcat.

Niveau 3-4-5 : Nous n'avons rien observé à ces niveaux.

Hors de l'architecture il y a la carte RasPi et la caméra qui sont des machines de l'attaquant et ne prennent donc pas place dans le modèle de Purdue.



1.3 Accès à la page d'authentification

Question 1.3 — *Accédez à la page d'authentification de l'interface de contrôle du système industriel.*

L'interface de contrôle est hébergée par `ihm.scada` (`192.168.95.5:9090`), nous établissons d'abord un tunnel ssh pour faire un port fowward local.

```
ssh -N -f -L 8090:192.168.95.5:9090 root@192.168.56.101 -p 2222
```

Listing 1 – Tunnel SSH vers l'IHM à travers la RasPi

Nous utilisons l'outil `gobuster` pour énumérer les path disponibles sur le serveur étant donné que la racine donne juste la page par défaut de Tomcat.

```
gobuster dir -u http://localhost:8090/ -w common.txt
```

Listing 2 – Énumération des chemins du serveur Tomcat

Nous trouvons le chemin intéressant `host-manager` et y accédons avec notre navigateur. Nous sommes par la suite interrogé par un dialogue HTTP basic auth. Voir capture pour tout le processus à la figure 2

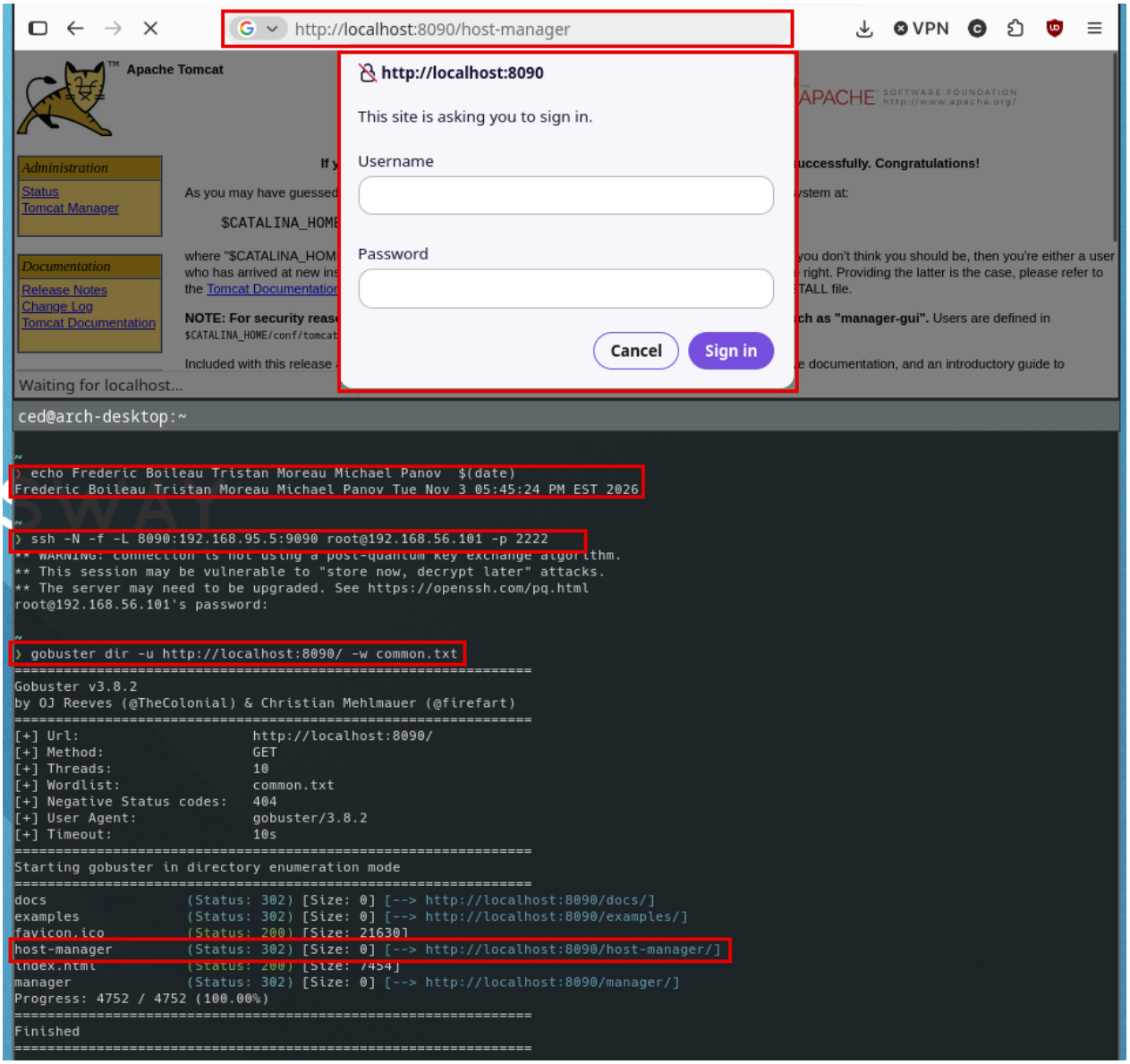


FIGURE 2 – Tunnel SSH, énumération des chemins et authentification de `/host-manager`

1.4 Tentative d'authentification

Question 1.4 — *Tentez une authentification avec les identifiants* `username=admin` *&* `password=admin`.

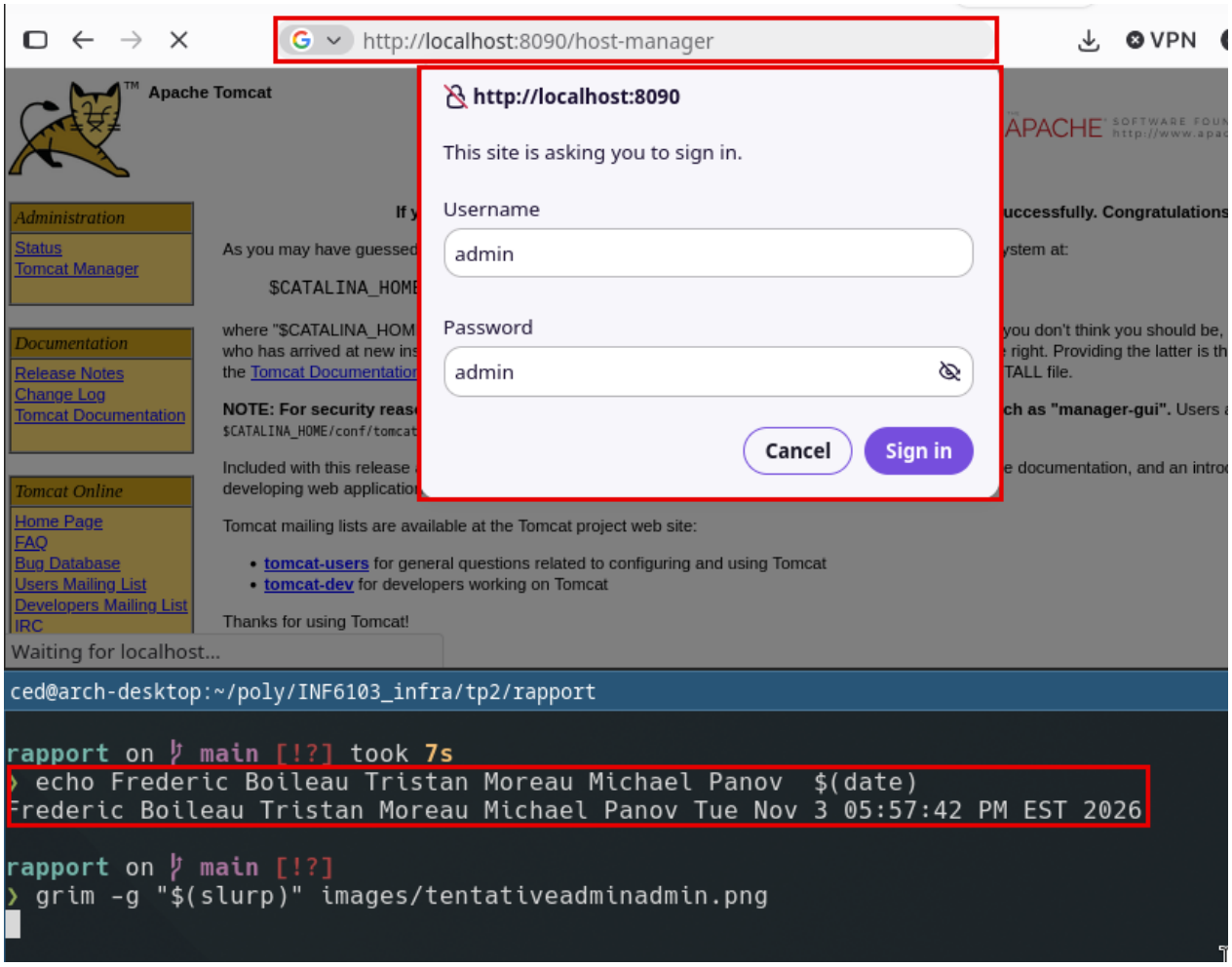


FIGURE 3 – Tentative d'authentification avec `admin`/`admin`